October 2026 security revision

Juan Carlos Nevarez · Gh0stlyKn1ght · github.com/Gh0stlyKn1ght

This edition **changes the four security article sources**. It is a technical revision beyond the earlier extraction/report. Original author credits and exact historical sources remain available. The updated handbook is the current reading path; the earlier 139-page reader remains a historical reference.

Review finding	**Change made**	**Remaining validation**
F01 · Keystore path	Corrected to the root containing `enclaves/`; startup and missing-path cases observed.	Repeat on the target deployment.
F02 · STRIDE error	Corrected Information Disclosure and added an evidence-aware method.	Model review against an actual mission.
F03 · Interoperability promise	Replaced with distribution/vendor scope and tested-combination requirements.	A separately recorded trial for each required combination.
F04 · Ambiguous SROS enabled field	Current records name prerequisites, controls, evidence and residual risk.	Runtime observations; historical table legend stays archived.
F05 · Mixed identity/hardware/ signing roles	Separated DDS credentials, host/ process boundaries, hardware protection and update signing.	Platform-specific key loading, recovery and revocation tests.
F06 · Crystal baseline	Current non-actuating Jazzy/DDS exercise; separate Lyrical platform decision. Historical robot models archived.	Target hardware and package compatibility.
F07 · DDS standard	Added 1.2 reference while retaining the distinction from actual implementation support.	Vendor-specific feature/standard matrix.
F08 · Transport scope	DDS-specific recipe labeled; Zenoh configuration and bridges discussed separately.	Zenoh/bridge deployment tests if selected.
F09 · Scores/evidence	Added 8 structured threat records with owners, prerequisites and residual risk. Old DREAD/RVSS scores remain historical.	Deployment-specific likelihood/ impact and accountable owners.
F10 · Proposed claims	Added explicit evidence states, runtime logs and result templates. Six ROS cases passed.	Separate-authority rejection evidence remains inconclusive.
Print layout	New editable vector figure and portrait updated handbook.	Physical printer proof remains absent.

Additional material includes a full lab recipe, restrictive policy, offline schema/XSLT generation and semantic grant checks, eight boundary tests, non-overwriting provisioning script, version capture, and technology recommendations. All five supporting articles now clarify the relevant security boundary: enclave commands, participant mapping, action names, the historical DDS overview, and the network-flow API discussion.

The follow-up repaired the served OAuth surface, pinned the Jekyll build, corrected the fork URL/base path, and checked the site in Chromium. A manual Pages workflow is prepared; publication is separately tracked. This does not imply a current CVE audit, robot deployment or hardware assessment.

Runtime and publication validation

Juan Carlos Nevarez · Gh0stlyKn1ght · October 20, 2026.

What was actually run

The non-actuating lab was executed using Ubuntu 24.04 Noble userspace and official ROS Jazzy packages in a private directory on the Kali workstation. Bubblewrap supplied separate user, PID and network namespaces. Only loopback was enabled for the communication tests, and the repository was mounted read-only. No ROS packages were installed into the host OS and no robot was attached.

The Ubuntu root image matched its official SHA-256 manifest; its GPG signature was not independently checked. The private image's `staff` group was mapped to namespace GID 0 to allow a fontconfig package post-installation step under the single-GID mapping. This was an execution environment, not a test of host isolation, a stock Ubuntu boot, or a hardened container product.

The installed baseline included **Fast DDS 2.14.7**, **rmw_fastrtps_cpp 8.4.4**, and **SROS 2 0.13.6**. Exact Debian package versions, the host kernel, selected settings, public runtime-artifact hashes, and sanitized logs are retained in `runtime-evidence/`. Authority keys and participant private keys remain outside the repository.

Observed ROS cases

Case	Observation	Result
Authorized pair	Seven messages published and received during the observation window; both participants stayed running.	Pass.
Missing enclave	Initialization failed without an artificial test shutdown; exit 250.	Pass.
Forbidden topic remap	Publisher creation failed; no application messages published; exit 250.	Pass.
Wrong identity profile	The talker executable under the listener identity failed to initialize its allowed profile; exit 250.	Pass, for whole-profile rejection.
Focused listener publishing probe	The listener node was constructed successfully, then `/chatter` writer creation was explicitly denied by Fast DDS; probe exit 2.	Pass, for application write denial.
Independently generated authority	Talker published seven messages; listener received zero. Both stayed running, but no explicit	**Inconclusive** for the claimed rejection mechanism.

Case	Observation	Result
	authentication rejection appeared in default logs.	
Authorized control repeated afterward	Seven messages published and received after the negative cases.	Pass.

Six of seven ROS cases passed. The complete suite is not reported as passing. The separate-authority observation meets the no-delivery expectation but does not by itself establish why delivery stopped.

A supplementary native Fast DDS probe recorded `AUTHENTICATION_ACCEPTED` for the trusted peer. The same probe with the independently created authority recorded neither acceptance nor rejection in its eight-second window. That result is retained, not converted into a rejection claim. Further discovery/handshake instrumentation is needed before closing this evidence gap.

The actual permissions XML generated by the installed SROS 2 package also passed the exact two-grant checks used by the offline example; see `runtime-permission-check.json`.

The two runtime enclave keys had mode `0600` in this environment. That checks group/other mode bits; it does not establish that privileged code, same-process code, mounts, or a different deployment account cannot access them.

Reproduce the software tests

On a prepared Jazzy host, provision two new lab directories using the documented setup script. Then run the runner with their separate keystores and a new output directory:

```
python3 examples/security-lab/run_runtime.py \
  --keystore /absolute/first/keystore \
  --untrusted-keystore /absolute/second/keystore \
  --output /absolute/new-results-directory
```

Run only on a non-actuating lab system. The runner uses domain 42 and localhost discovery, scopes shutdown to the processes it starts, refuses to reuse an output directory, and returns a nonzero status if any case fails or is inconclusive. Review the logs and version manifest before comparing results across machines.

The optional `authentication_probe.cpp` targets the Fast DDS 2.14 API and requires that version's headers/libraries and a C++ compiler. Its native callback observations are separate from the ROS application delivery cases; it does not replace them.

Website checks

The site was built with Jekyll 4.4.1 and a committed dependency lockfile. Its fork URL and `/design` base path replace the inherited upstream domain configuration. The public site uses static navigation: inherited OAuth/token-storage scripts, third-party analytics, and the old login route are excluded from the served output. This is a focused repair of the published surface, not a full dependency or vulnerability audit.

All four revised security pages and the landing page loaded in Chromium. A static sweep checked 131 local links/assets across those pages. PDF downloads, the vector figure, and an exact historical source download returned successfully. No JavaScript errors, failed assets, or mobile horizontal overflow were observed.

The historical sources retain front matter and Liquid snippets. The site build excludes them from Jekyll processing and copies them as exact downloads afterward; this prevents archived permalinks or includes from replacing the revised pages.

Publication is separately tracked. A local build/browser check does not prove a GitHub Pages deployment. The Pages workflow is manual, and deployment verification must compare its source commit and handbook hash with `site-build.json` after publication.

Printer proof and remaining limits

Two one-page proofs were submitted to the connected HP LaserJet: a portrait lab-command page and the landscape diagram. CUPS reported both jobs completed. Physical orientation, clipping and readability still need the user's observation; spool completion is not paper verification.

Still unverified: any physical robot, actuator safety, revocation/expiry and recovery behavior, hardware-backed keys, privileged-host isolation, bounded overload behavior, and packet-level confidentiality. The separate-authority case remains inconclusive as described above. No new vulnerability assessment or compliance conclusion is claimed.

Libraries and technology choices

Juan Carlos Nevarez · Gh0stlyKn1ght · Reviewed October 20, 2026.

Use a small stack with clear boundaries: SROS 2 for DDS identity/policy material, a reviewed XML check for the example policy, Graphviz for editable vector diagrams, and WeasyPrint for predictable paper output. The choices below distinguish tools used in this edition from deployment options that need a target-system trial.

Adopted in this edition

Technology	Purpose and reason	Limit
SROS 2 policy 0.2.0	ROS-oriented privileges and a path to signed DDS permission artifacts. The offline example uses a pinned upstream schema and transform.	A valid policy and signed file still need actual middleware enforcement tests.
Python + lxml	Schema validation, the upstream XSLT, exact grant assertions and input-boundary checks. Schema resolution is local; DTDs and XInclude are rejected for this example.	The checker accepts this defined format, not arbitrary external XML/XSLT.
Graphviz DOT → SVG/PDF	Editable architecture source and sharp monochrome diagrams on paper. The build records the installed tool version.	Diagram boundaries are design claims until their controls are verified.
Markdown + WeasyPrint	Source-controlled chapters, paged CSS, bookmarks, embedded fonts and US Letter output. Keep the tested 69.0 renderer pinned for this edition.	Library version alone does not establish PDF accessibility or printing correctness.
JSON threat register and result template	Stable IDs, prerequisites, owners, evidence states and residual-risk notes, rendered into printable records.	No automatic risk score substitutes for a deployment-specific judgment.
Poppler tools	Inspect every PDF page size, embedded fonts, extracted text and record coverage.	A rendered PDF check is not physical printer evidence.

Primary documentation: SROS 2, lxml resolution and XSLT access control, Graphviz SVG, and WeasyPrint PDF guidance. The WeasyPrint documentation describes newer releases too; this package records what it actually used. A future PDF/UA export needs semantic review and an independent conformance check before claiming accessibility compliance.

Middleware and platform decisions

For the included exercise: use Jazzy on Ubuntu 24.04 with `rmw_fastrtps_cpp`. This keeps the commands and policy aligned with a reviewed official tutorial and the pinned Jazzy transformation. Capture installed package versions; do not infer package versions from the ROS distribution name. The isolated run recorded six passed ROS cases and one inconclusive separate-authority case; consult the runtime observations before relying on a particular claim.

For a new long-lived robot: evaluate Lyrical on Ubuntu 26.04 when its hardware/application dependencies are supported. Lyrical's official support horizon is May 2031; Jazzy remains listed through May 2029. The decision depends on drivers, vendor support, package availability, and a measured migration run. See the official release table and Lyrical platform matrix.

Fast DDS is a suitable starting point for this DDS-focused lab. **Cyclone DDS** is a credible alternate implementation for a separately tested deployment; both document security plugins and signed governance/permissions. Neither is declared “more secure” here, and no performance benchmark was run. Choose based on supported packaging, required features, operational evidence and vendor support. The Jazzy tutorial does not support secure cross-vendor communication. Sources: Fast DDS security, Cyclone DDS security, and Jazzy tutorial.

Zenoh is an option when its routing/topology model fits the application. The current `zenoh_security_tools` can generate session configs using SROS 2 policy and keystore material. Its router/session settings and bridge boundaries need their own review; switching `RMW_IMPLEMENTATION` is not a complete migration of DDS security. Source: official Zenoh security tools. This option is documented, not installed or validated in this package.

Useful next-stage tools

- **OWASP Threat Dragon desktop:** useful when several people want a visual data-flow editor with threat/remediation records and local files. Keep the JSON register as a reviewable artifact and check export compatibility with old diagrams. It is optional; the authored DOT/SVG figure already works offline. Threat Dragon documentation.
- **Syft + Grype:** useful for dependency inventory and vulnerability triage of a selected deployment image/filesystem. Record tool versions, artifact digest, database age and exceptions. An SBOM is not evidence that a vulnerability is exploitable; a clean scan does not prove safety. These tools were researched, not run. Syft, Grype.
- **Cosign:** useful when an actual release pipeline needs artifact-signature verification. Define the accepted signing identity/issuer or trusted key and verify the intended artifact digest. Keep this release-signing trust separate from DDS identities. No signing integration was configured. Cosign verification.

The most useful next investment is stronger instrumentation for the inconclusive separate-authority case, followed by a small current-robot case study. Introducing more tooling before those results would not strengthen the handbook's evidence.